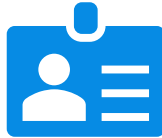


Authentication VS. Authorization



Authentication vs. Authorization



Authentication

Are you who you say you are?

Proving that you are who you say

Password

Verification of identity

Multi-factor authentication

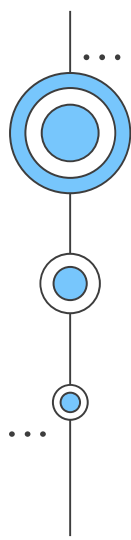


What is the authenticated person allowed to do?

Authorization

Granting permission to an authenticated party to do something

Role-based access control (RBAC)

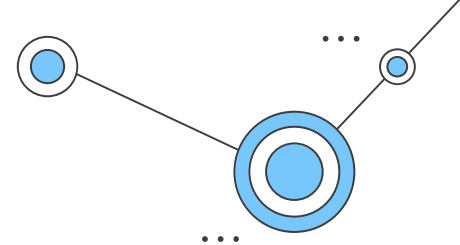


Azure Active Directory (Azure AD)



Azure Active Directory (Azure AD)

Azure's identity and access management service

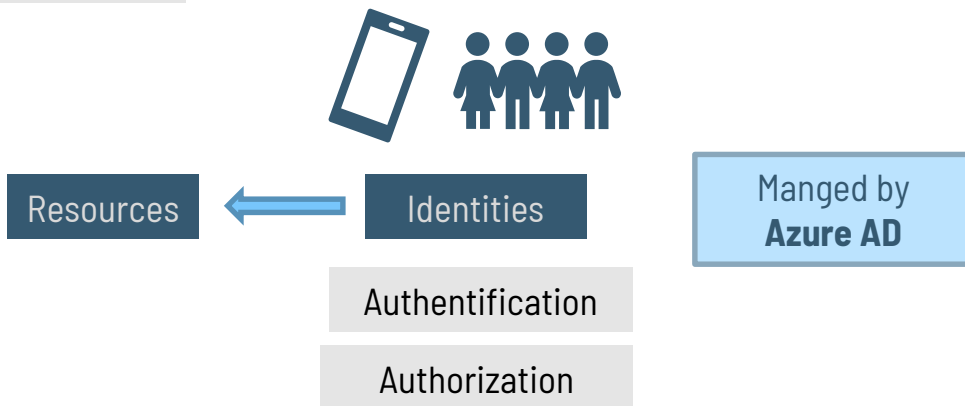


Helps employees to access resources and applications

Managed service - "identity-as-a-service"

Microsoft 365

Azure portal



Users

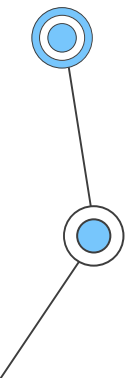
Credentials

Groups

Multi-factor authentication

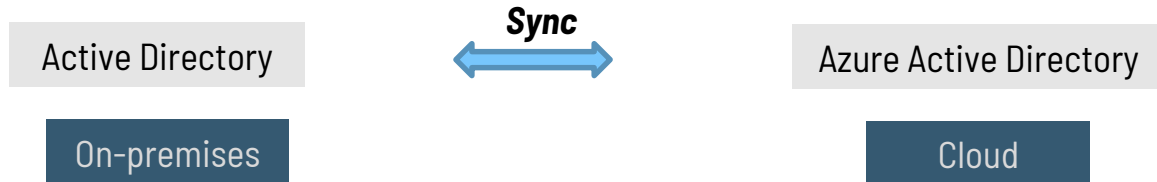
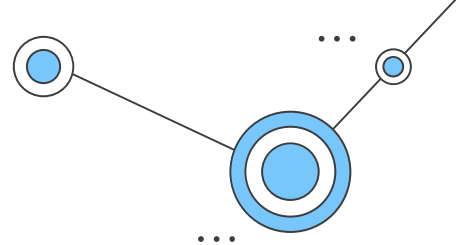
Single-sign-on (SSO)

Guest access



Azure Active Directory (Azure AD)

Azure's identity and access management service



Plans

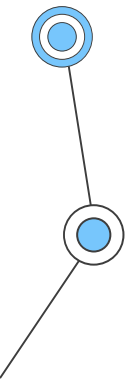
Azure Active Directory Free

Azure Active Directory Premium P1

Azure Active Directory Premium P2

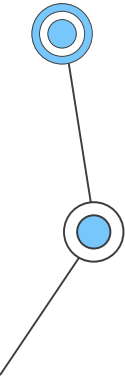
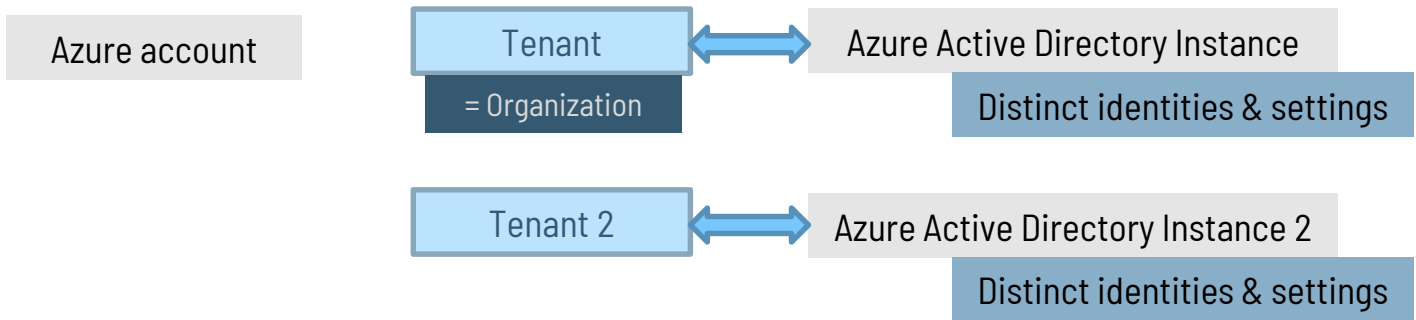
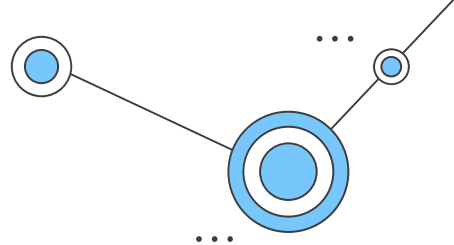
Additional features

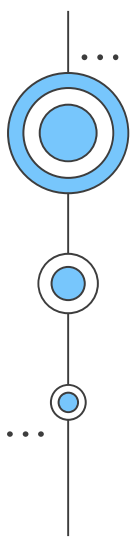
99.9% availability SLA



Azure Active Directory (Azure AD)

Azure's identity and access management service



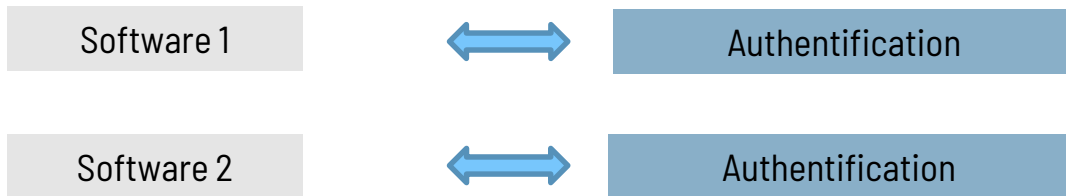
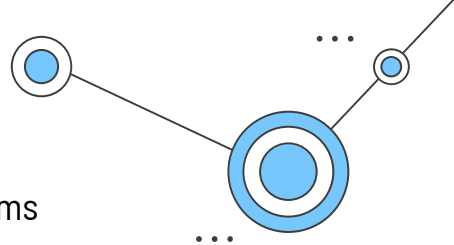


Single sign-on (SSO)

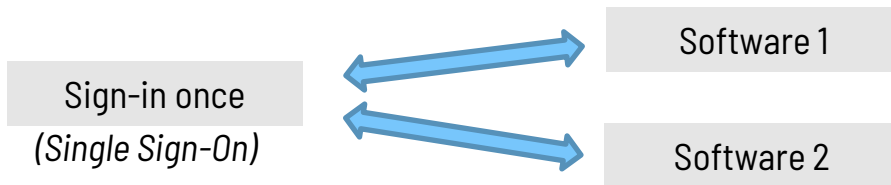


Single sign-on (SSO)

Sign in with one set of credentials to multiple independent software systems

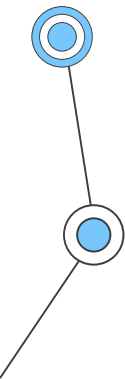


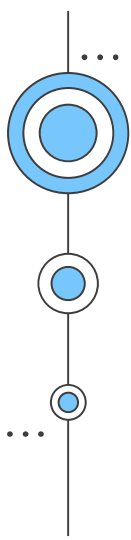
Insecure + Inconvenient



Azure AD

Easy to manage + more secure



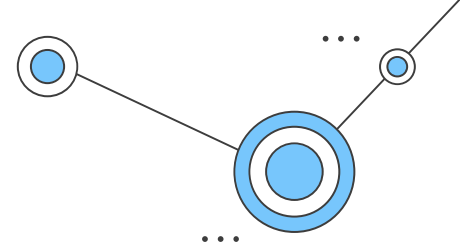


Multi-Factor Authentication



Multi-Factor Authentication

Additional method of authentication



Username: nikolai.schuler@[...] .com

Password: *****



Authentication

Password can get found out!

One way:
Conditional Access



2nd authentication factor



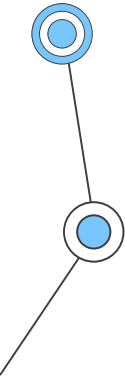
Something you ...

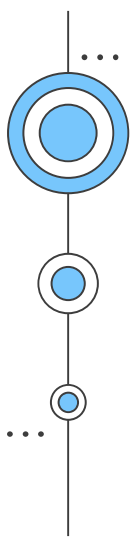
... Know

... Have

... Are

Password: *****

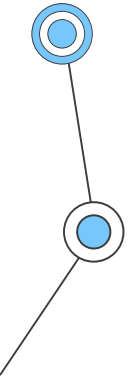
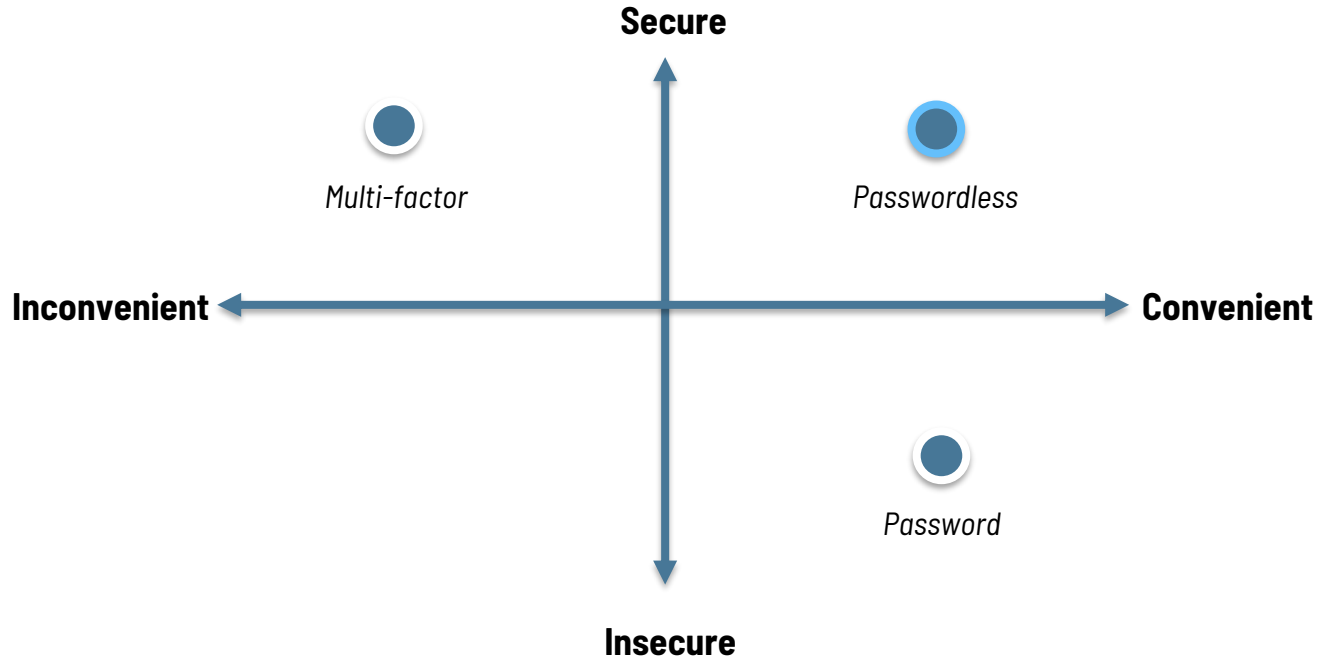
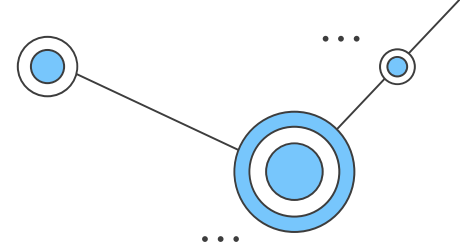




Passwordless authentication

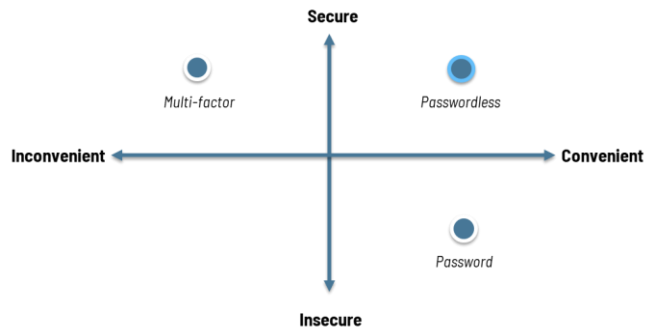
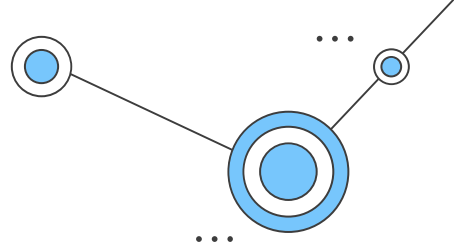


Passwordless authentication



Passwordless authentication

More secure + more convenient



3 passwordless options

Windows Hello for Business

Credentials connected to Windows device
Face recognition, 4-digit PIN

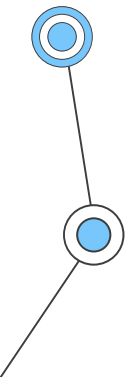
Microsoft authenticator app

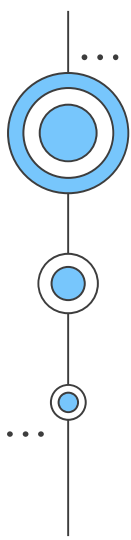
App on user's phone
Push notification + PIN or biometrics

FIDO2 Security Key

Open standard for passwordless
Hardware devices like finger print etc.

All supported by Azure AD!





Guest access



Guest access

Inviting external users



Internal users

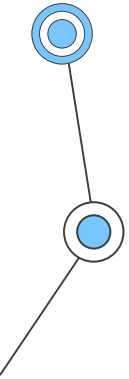
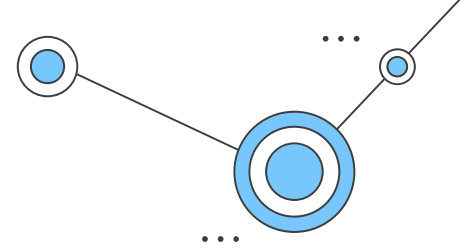
Members of the organisation



External users

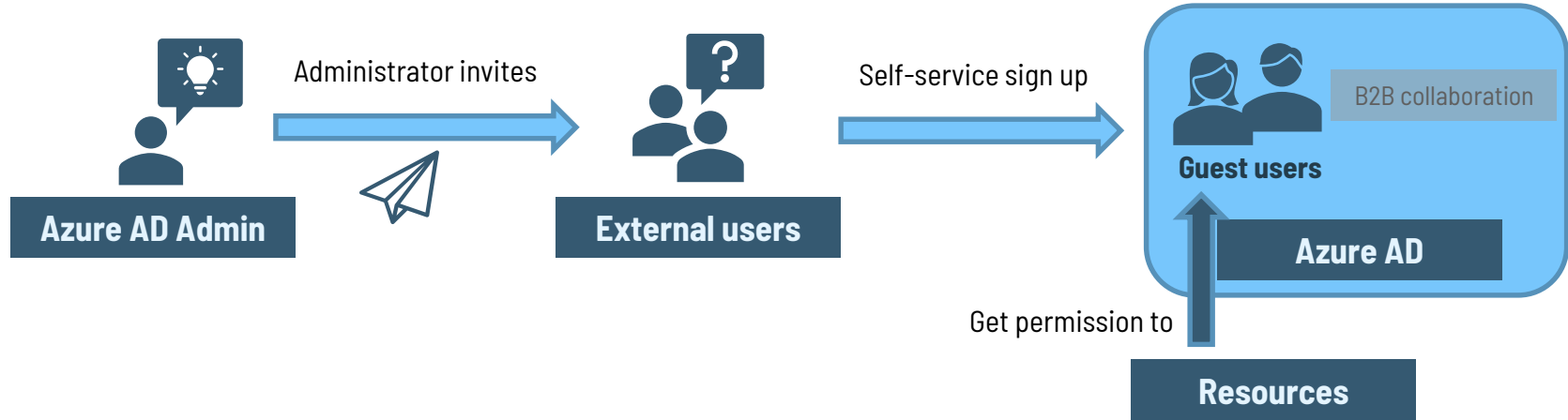
Not members of the organisation

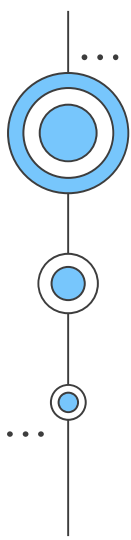
From different tenant or not Azure users at all



Guest access

Inviting external users



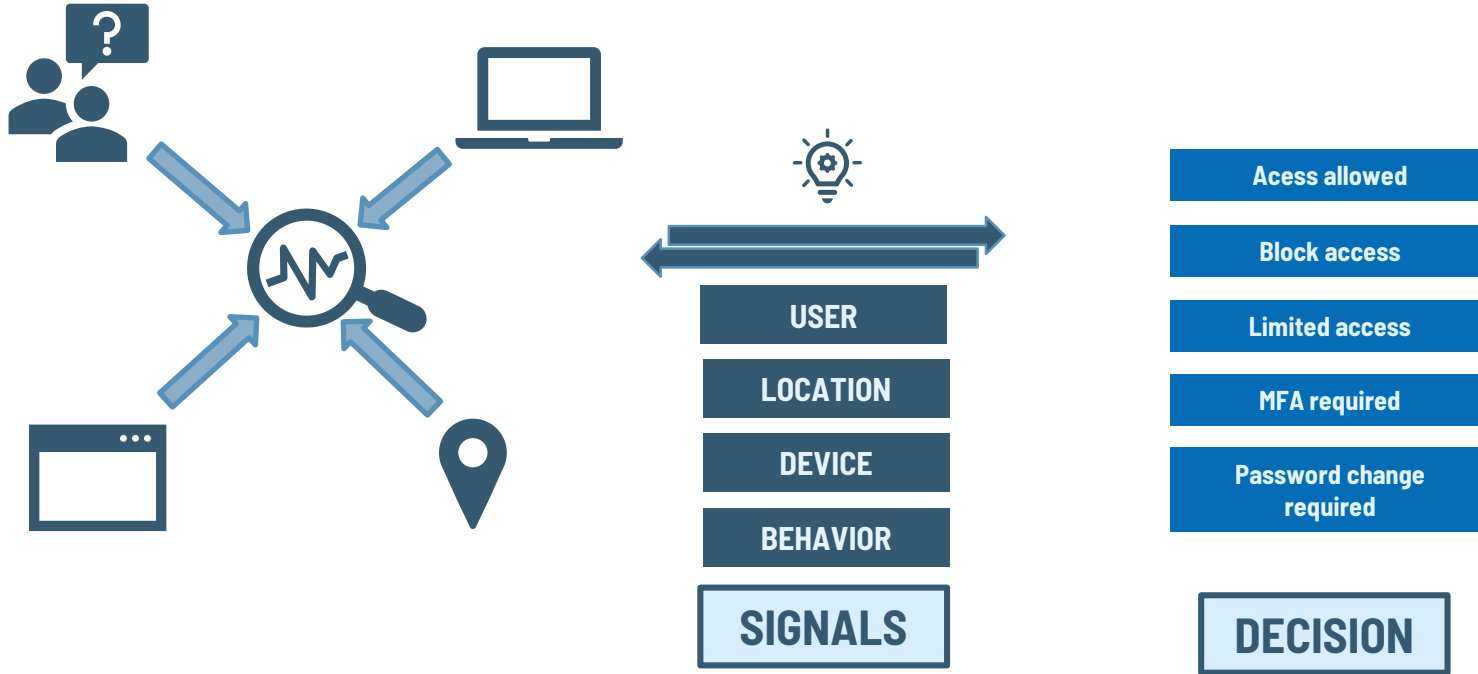


Conditional access



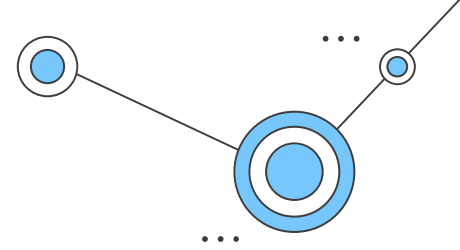
Conditional access

Including intelligent signals in access control decisions



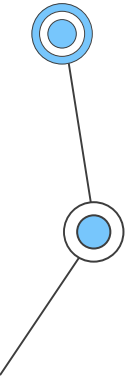
Conditional access

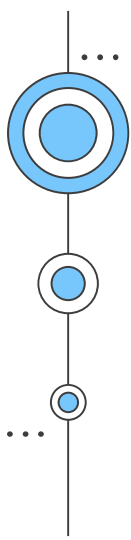
Including intelligent signals in access control decisions



Examples:

- Administrators always require MFA
- Access from specific countries is not allowed at all
- Unusual location requires MFA
- User outside of the company's network generally require MFA



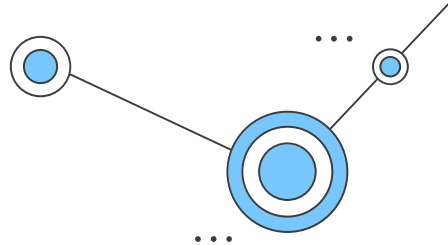


Role-based access control (RBAC)



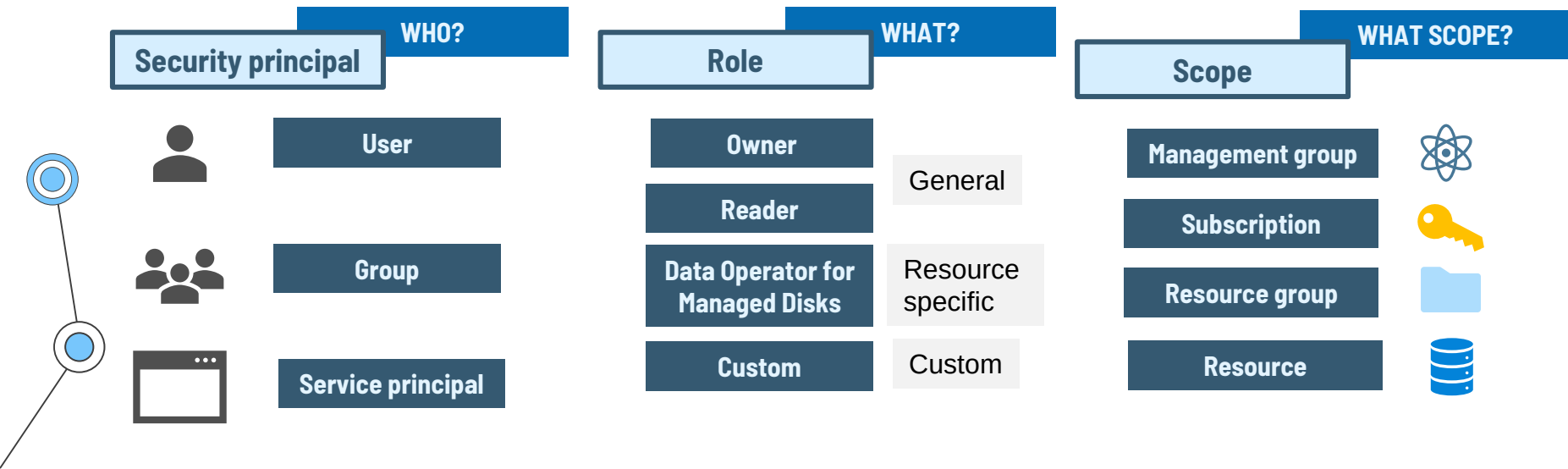
Role-based access control (RBAC)

Access management to resources



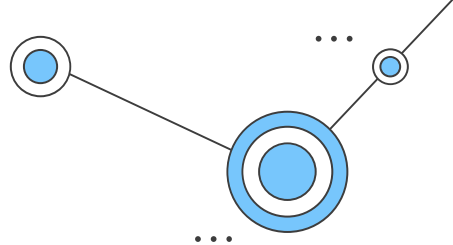
Authorization: Configure access for users and groups to resources

Example: Allow one user to manage all SQL databases in a resource group.



Role-based access control (RBAC)

Access management to resources



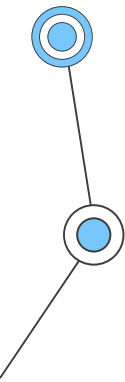
Examples:

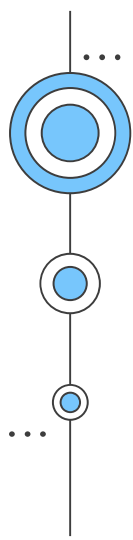
- **One user** gets assigned the role **Reader** to an **entire resource group**.
- **One user group** gets assigned the role **Storage account contributor** to **three storage accounts**.

Security principal

Role

Scope



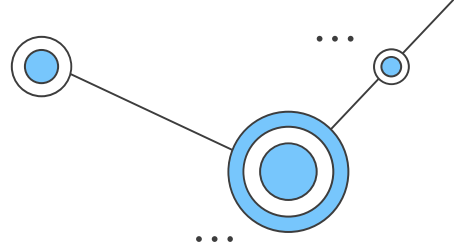


Zero Trust



Zero Trust

Modern security principals

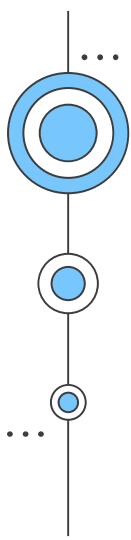


Strategy: Follow the following security principals:

- **Assume breach**
End-to-end encryption, network segmentation, analytics, threat detection, continuous monitoring, updates
- **Use least privilege access**
Limit access to what is just enough
Just-In-Time (JIT) and Just-Enough-Access (JEA)
- **Verify explicitly**
Use all data points and every opportunity to authenticate and authorize

Zero Trust mindset: “assume breach, never trust, always verify”



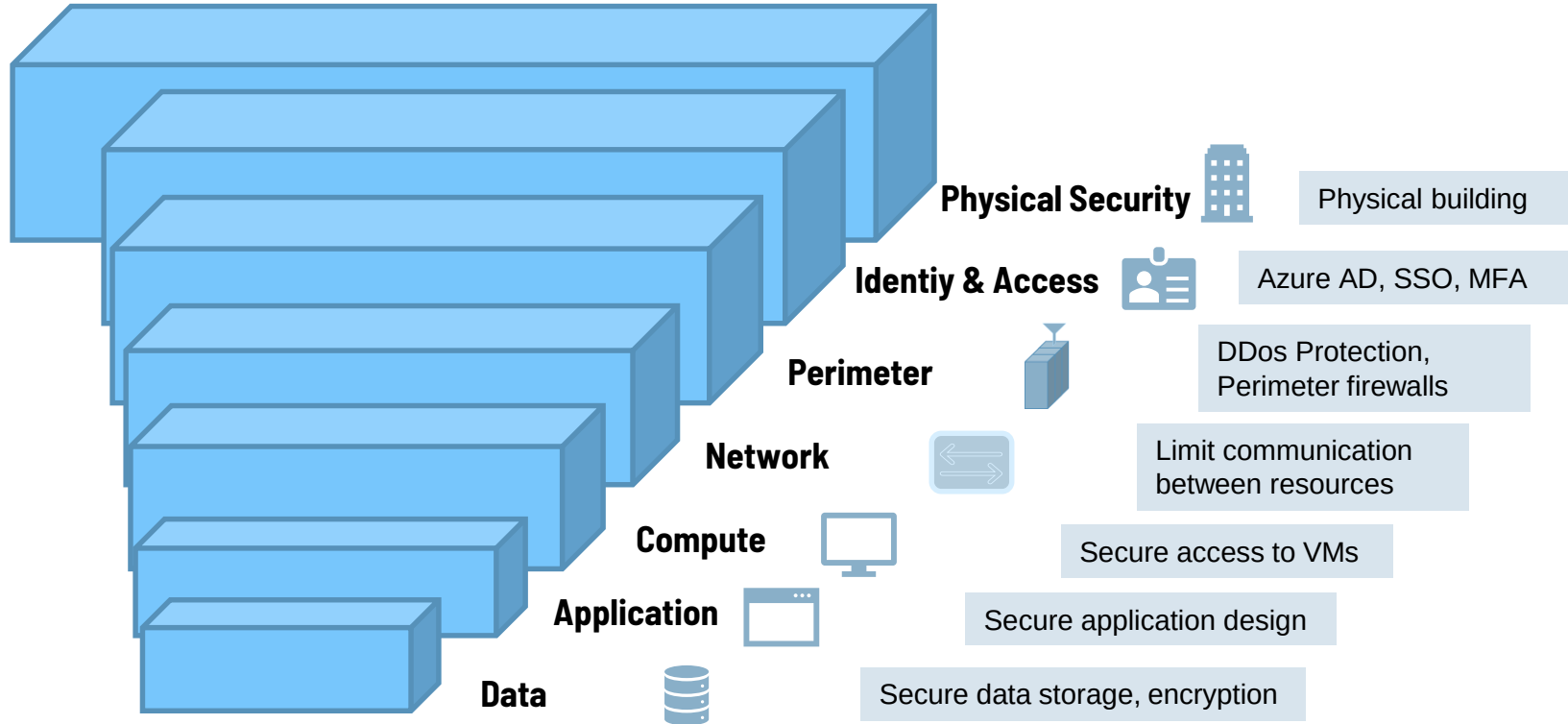


Defense in depth

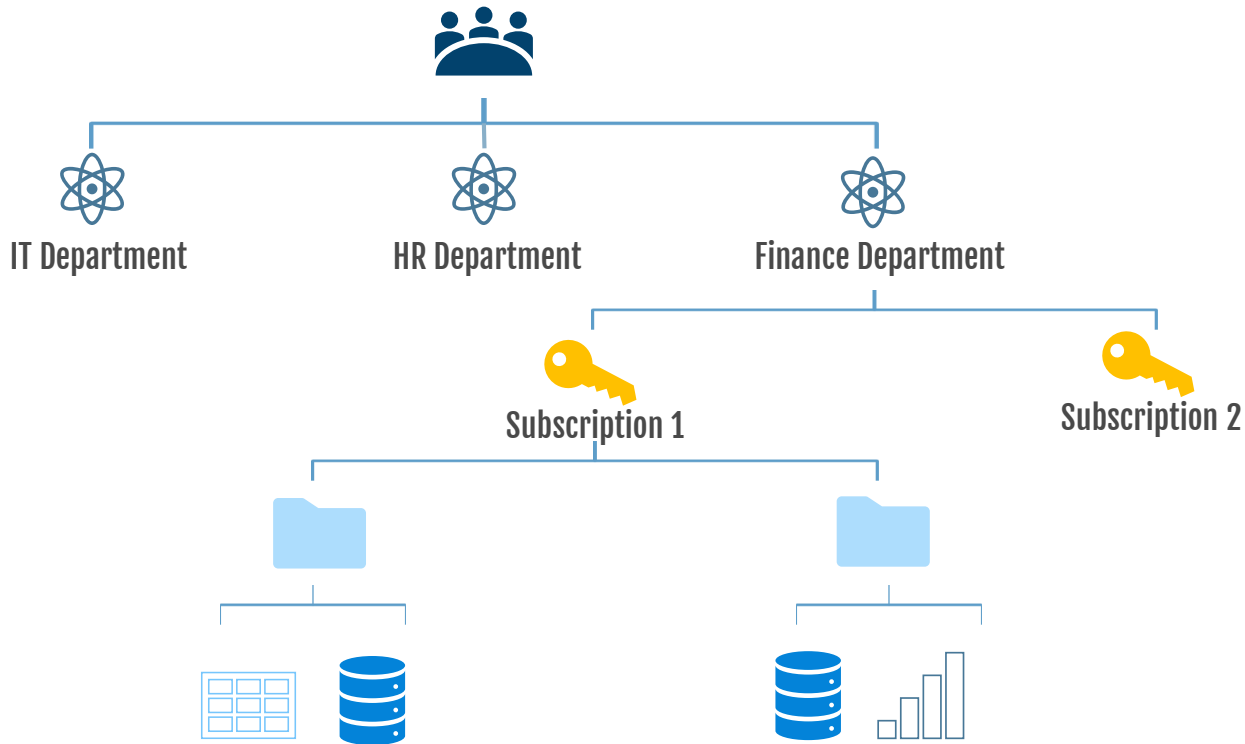


Defense in depth

Multiple layers of security



Subscription and management groups



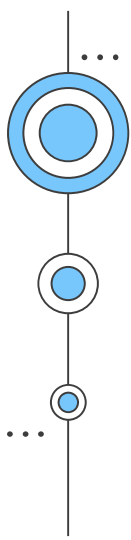
Azure Account

Management groups

Subscriptions

Resource groups

Resources

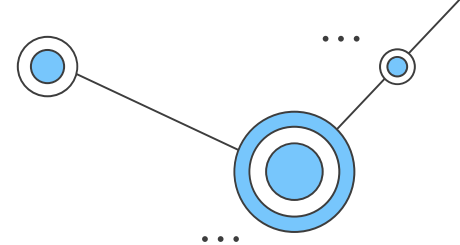


Microsoft Defender for Cloud



Microsoft Defender for Cloud

Security tools for cloud and on-premises



Azure cloud

Multicloud

On-premises

Two pillars of security

Security posture

Security score that continuously assesses your security situation

Continuous Assessment

Security recommendations

Recommendations as step-by-step actions on how to improve your security posture

Secure

Alerts

Defends in real-time and sends alerts

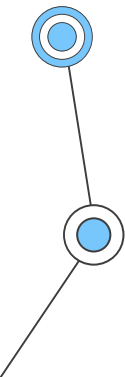
Defend

CSPM
Cloud Security Posture Management

Free service

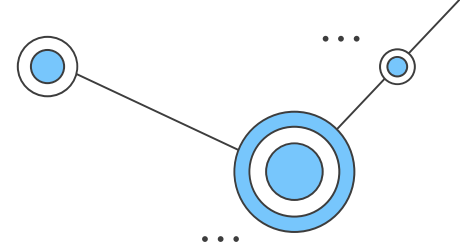
CWPP
Cloud Workload Protection Platform

Paid service



Microsoft Defender for Cloud

Security tools for cloud and on-premises



Security posture

Continuous Assessment

Free services

- Security score = assessment of vulnerabilities
- Regulatory compliance
- Asset inventory

Security recommendations

Secure

- Security recommendations
- Just-in-time VM access
- Adaptive application controls

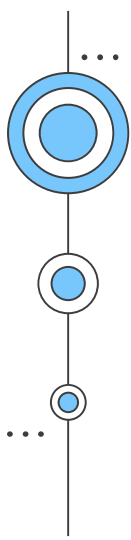
Alerts

Defend

Paid service

- Security alerts
- Defends and detects
- Intelligent threat detection





Summary



Summary

Authentication

Proving that you are who you say

Authorization

Granting permission to an authenticated party to do something

Azure AD

Managed service for identity and access management (Azure & 0365)

Azure AD Connect: Sync on-premise Active directory & Azure AD

Free plan and premium plans (99.9% availability)

Authentication & Authorization

Distinct from other resources & services

Invite external users (guest users)

Multi-factor Authentication

Additional method of authentication

Biometrics or trusted device

Single sign-on

One set of credentials to sign in to multiple systems

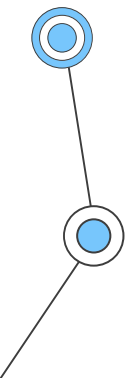
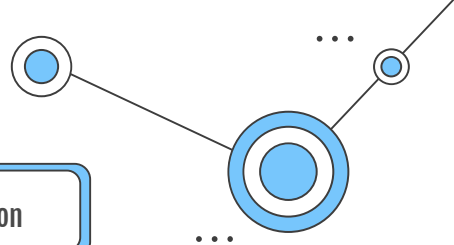
Passwordless

Secure + convenient

Windows Hello for Business

Microsoft authenticator app

FIDO2 Security Key



Summary

Conditional access

Including intelligent signals in access control decisions
E.g. Administrator needs to use MFA

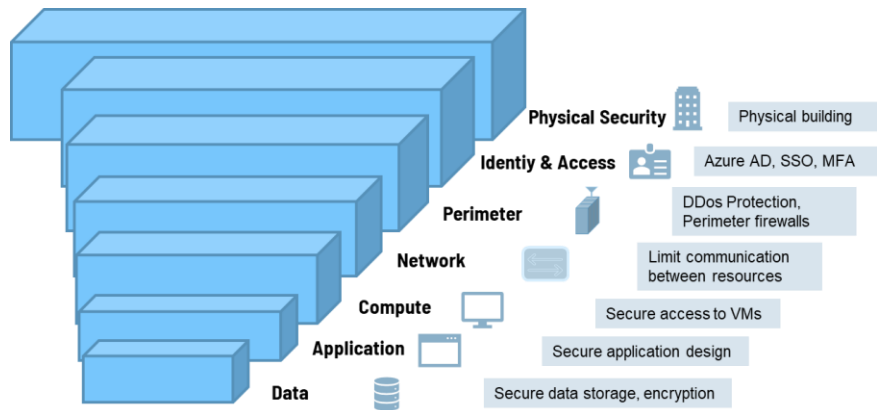
Role-based access control (RBAC)

Authorization: Configure access for users and groups to resources
Allow one user to manage all SQL databases in a resource group

Zero Trust

Security principals: Assume breach, never trust, always verify!

Defense in depth



Microsoft Defender for cloud

Security tools for cloud (Azure + multicloud) and on-premises
Security score, security recommendations and alerts